ISO 27001

Seguridad de la Información – ISO 27001

Política de Seguridad Física y Medioambiental

Esteban Chamblat Rojas

TABLA DE CONTENIDO

1. **INTRODUCCIÓN** 1
2. **OBJETIVO** 1
3. **ALCANCE** 1
4. **DIRECTRICES** 2
    - 4.1 Selección de Proveedores de Servicios en la Nube
    - 4.2 Modelo de Responsabilidad Compartida
    - 4.3 Seguridad de los Datos en la Nube
    - 4.4 Gestión de Identidades y Accesos (IAM)
    - 4.5 Configuración y Despliegue Seguro
    - 4.6 Monitoreo y Auditoría en la Nube
    - 4.7 Respuesta a Incidentes y Continuidad

CLASIFICACIÓN: USO INTERNO | COPIA CONTROLADA *Documento propiedad de Pepito paga doble. Prohibida su reproducción total o parcial sin autorización.*

Seguridad de la Información – ISO 27001

Información del Documento	Detalle
Autor del Documento	Esteban Chamblat
Fecha de Creación	22/02/2025
Clasificación	Uso Interno / Confidencial

HISTORIA DE CAMBIOS DE VERSIÓN DEL DOCUMENTO

Versión	Fecha	Autor	Descripción
1.0	22-02-2025	Esteban Chamblat	Creación de documento

1. INTRODUCCIÓN

En **Pepito paga doble**, la adopción de servicios en la nube es fundamental para la escalabilidad de nuestras plataformas de middleware **OpenTux** y la gestión de microservicios. Esta política establece los controles necesarios para mitigar los riesgos asociados a la externalización de servicios y el almacenamiento de datos fuera del perímetro físico tradicional.

2. OBJETIVO

Definir los requisitos de seguridad para el uso de servicios en la nube en **Pepito paga doble**, garantizando que la información procesada en infraestructuras híbridas (nube y entornos locales de **Proxmox**) mantenga los niveles de confidencialidad, integridad y disponibilidad requeridos por la organización.

3. ALCANCE

Esta política aplica a todos los servicios de Infraestructura como Servicio (IaaS), Plataforma como Servicio (PaaS) y Software como Servicio (SaaS) contratados por **Pepito paga doble**, incluyendo clústeres de **Docker Swarm**, bases de datos **PostgreSQL** y sistemas de respaldo **Veritas NetBackup**.

4. DIRECTRICES

4.1 Selección de Proveedores de Servicios en la Nube

CLASIFICACIÓN: USO INTERNO | COPIA CONTROLADA *Documento propiedad de Pepito paga doble. Prohibida su reproducción total o parcial sin autorización.*

- Solo se podrán contratar proveedores que demuestren cumplimiento con estándares internacionales de seguridad.
- La evaluación técnica de los proveedores será realizada exclusivamente por **Esteban Chamblat**.

4.2 Modelo de Responsabilidad Compartida

- **Pepito paga doble** asume la responsabilidad de la configuración de seguridad de los sistemas operativos **Rocky Linux** y la protección de los datos.
- El proveedor es responsable de la seguridad física y de la capa de virtualización subyacente.

4.3 Seguridad de los Datos en la Nube

- Toda información clasificada como confidencial debe ser cifrada tanto en tránsito (TLS/SSL) como en reposo (AES-256).
- Las llaves de cifrado deben ser gestionadas de forma segura y nunca almacenadas junto con los datos.

4.4 Gestión de Identidades y Accesos (IAM)

- El acceso a las consolas de administración de la nube debe estar restringido mediante Autenticación Multifactor (MFA).
- Se deben utilizar servicios de resolución de nombres **PowerDNS** para asegurar la conectividad confiable entre los entornos locales y la nube.

4.5 Configuración y Despliegue Seguro

- Los despliegues en contenedores mediante **Docker Swarm** deben seguir plantillas de endurecimiento (hardening) previamente aprobadas.
- El tráfico de red debe ser filtrado rigurosamente mediante las reglas de firewall definidas en nuestros sistemas **pfSense**.

4.6 Monitoreo y Auditoría en la Nube

- Todos los servicios en la nube deben estar integrados en nuestra plataforma de monitoreo **Zabbix**.
- Se deben recolectar y revisar periódicamente los logs de acceso y de cambios en la configuración para detectar anomalías o intentos de intrusión.

CLASIFICACIÓN: USO INTERNO | COPIA CONTROLADA *Documento propiedad de Pepito paga doble. Prohibida su reproducción total o parcial sin autorización.*

4.7 Respuesta a Incidentes y Continuidad

- En caso de un incidente de seguridad en la nube, se activarán los protocolos de respuesta liderados por la Unidad de TI.
- Los respaldos críticos se enviarán fuera de la nube hacia nuestra infraestructura local protegida por **Veritas NetBackup** para evitar la dependencia total de un solo proveedor.

CLASIFICACIÓN: USO INTERNO | COPIA CONTROLADA *Documento propiedad de Pepito paga doble. Prohibida su reproducción total o parcial sin autorización.*